



منهجية تقييم ومعالجة مخاطر الأمن السيبراني

التصنيف: داخلي

Version	Approved By	Owner	Date Last Updated	Review Frequency	Next Review	Comments
1.0	عبدالله المحيسن – رئيس مجلس الإدارة	سارة الحربي – مديرة أمن المعلومات (CISO)	2026-09-12	سنوياً	2027-09-12	الإصدار الأول – إنشاء منهجية تقييم المخاطر لبنك الآفاق الرقمية

المحتويات

البند	العنوان	الصفحة
1	الغرض من هذه الوثيقة	1
2	سجل المخاطر	2
3	الأدوار والمسؤوليات	2
4	ملخص المنهجية	2
5	تحديد المخاطر	3
6	خطط المعالجة	8
7	التصعيد	8

Purpose of This Document (الغرض من هذه الوثيقة)

تحدد الوثيقة التالية النهج العام لأمن المعلومات داخل بنك الآفاق الرقمية. وهي مخصصة كإرشاد للجوانب الحاسمة لإدارة المبادئ الأساسية لمخاطر أمن المعلومات. المحتوى مخصص للموظفين والمدققين والموردين والعملاء. يمكن العثور على تفاصيل داعمة إضافية في السياسات والإجراءات المشار إليها.

The Risk Log (سجل المخاطر)

يمكن العثور على سجل مخاطر أمن المعلومات في: **REQUIRED-ISMS-FORM-06-1 Asset-Based Risk Tool.xlsx** الملف المخصص لتقييم المخاطر

Roles & Responsibilities (الأدوار والمسؤوليات)

لجنة أمن المعلومات (Information Security Group – ISG)

برئاسة سارة الحربي (CISO) وعضوية:

- فهد العتيبي (CIO)
- أحمد الغامدي (المراجعة الداخلية)
- ليلى الدوسري (الشؤون القانونية)
- خالد الشمري (الموارد البشرية)

مسؤولياتها:

- وضع سياسة إدارة المخاطر وأهدافها وشهية المخاطر في البنك.
 - تخصيص الموارد اللازمة لدعم عملية معالجة المخاطر.
 - ضمان توافق أنشطة معالجة المخاطر مع الأهداف الاستراتيجية الشاملة للبنك.
- مصدر التعديل: دراسة الحالة – القسم 2.1 (الهيكل التنظيمي) + القسم 5.1 (توقعات الإدارة العليا)

مالكو المخاطر (Risk Owners)

- تحديد وتقييم المخاطر المرتبطة بمجالات مسؤوليتهم المحددة.

- تحديد معايير المخاطر ومستويات المخاطر المقبولة.
- اختيار خيارات معالجة المخاطر المناسبة (القبول، التجنب، النقل، التخفيف) بناءً على شهية المخاطر ومعايير البنك.
- تنفيذ ومراقبة خطط معالجة المخاطر.
- الإبلاغ عن تقدم معالجة المخاطر.

مالكو المخاطر في بنك الأفاق:

المجال	مالك المخاطر
البنية التحتية والشبكات	فهد العتيبي (CIO)
الأنظمة المصرفية الأساسية	فهد العتيبي (CIO)
تطوير البرمجيات	مدير تطوير البرمجيات
قواعد البيانات	مدير قواعد البيانات
الموارد البشرية	خالد الشمري (HR Manager)
الشؤون القانونية	نبلى الدوسري
العمليات المصرفية	مدير العمليات المصرفية
الموردين والأطراف الثالثة	مدير المشتريات

مصدر الأسماء: دراسة الحالة – القسم 2.1 (الهيكل التنظيمي)

مسؤول أمن المعلومات (Information Security Officer – ISO)

من فريق حوكمة أمن المعلومات برئاسة سارة الحربي:

- تطوير وصيانة منهجية معالجة المخاطر والأدوات والتقنيات المرتبطة بها.
- تقديم الإرشاد والدعم لمالكي المخاطر وأصحاب المصلحة في عملية معالجة المخاطر.
- مراقبة التقدم والفعالية الإجمالية لمعالجة المخاطر.
- الإبلاغ عن عملية معالجة المخاطر إلى الإدارة العليا وأصحاب المصلحة ذوي الصلة.
- تنسيق أنشطة معالجة المخاطر.

مصدر التعديل: دراسة الحالة – القسم 2.1 (فريق حوكمة أمن المعلومات)



Risk Identification (تحديد المخاطر)

يمكن أن يأتي تحديد المخاطر الأمنية من خلال العديد من الطرق. داخل بنك الأفاق الرقمية، تشمل هذه الطرق، على سبيل المثال لا الحصر:

المصدر	الوصف
المراجعة السنوية لسياق البنك	أي تغييرات في النطاق أو أصحاب المصلحة أو التشريعات قد تدخل مخاطر جديدة
مراقبة التهديدات الناشئة	من خلال تنبيهات الموردين، تحديثات وسائل الإعلام، وإشعارات الهيئة الوطنية للأمن السيبراني (NCA)، والبنك المركزي السعودي (ساما)
تحليل SWOT	مراجعة نقاط القوة والضعف والفرص والتهديدات في البنك (سنوياً)
تفاعل أصحاب المصلحة	ملاحظات من الموظفين داخل وخارج البنك
التدقيق الأمني	التدقيق الخارجي، اختبارات الاختراق والثغرات (البنك يجري فحصاً ربع سنوي للثغرات)
تقييم مخاطر الأنظمة الحرجة	مراجعة شاملة للمكونات والمخاطر المحتملة على استمرارية تشغيلها

Risk Assessment (تقييم المخاطر)

يتم بعد ذلك تقييم كل خطر بناءً على احتماليته (Likelihood) وأثره (Impact). تشير الاحتمالية إلى احتمال حدوث الخطر، بينما يمثل الأثر العواقب المحتملة إذا تحقق الخطر.

اختار بنك الأفاق الرقمية استخدام مقاييس القياس التالية:

مقياس الاحتمالية (Likelihood)

مصدر التعديل: القالب – الصفحة 4 (مع تعديل الأمثلة لتناسب البنك)

الدرجة	الوصف	الشرح
1	بعيد (Remote)	الخطر غير محتمل الحدوث في الظروف العادية. لا توجد حالات معروفة أو حالات نادرة فقط في بيانات مماثلة.
2	غير محتمل (Unlikely)	الخطر لديه فرصة منخفضة للحدوث. قد يحدث في ظروف استثنائية لكن لا يُتوقع حدوثه بانتظام.
3	ممکن (Possible)	الخطر لديه احتمال معتدل للحدوث. هناك فرصة متساوية لحدوثه أو عدم حدوثه.
4	محتمل (Probable)	الخطر أكثر عرضة للحدوث من عدمه. هناك حالات سابقة في سياقات مماثلة أو عوامل تزيد من احتماليته.
5	محتمل جداً (Highly Probable)	الخطر شبه مؤكد الحدوث. أدلة قوية أو بيانات تاريخية تشير إلى تكراره في بيئة البنك.

مقياس الأثر (Impact)

مصدر التعديل: القالب – الصفحات 5-6 (مع تعديل الأمثلة لتناسب البنك)

الدرجة	الوصف	الشرح
1	ضئيل (Insignificant)	الأثر لا يكاد يُذكر، مع عدم وجود عواقب ملحوظة على العمليات أو السمعة أو المالية.
2	بسيط (Minor)	الأثر يسبب إزعاجاً بسيطاً يمكن إدارته أو حله بسهولة. قد يؤدي إلى تأخير طفيف أو تكاليف بسيطة.
3	معتدل (Moderate)	الأثر ملحوظ وقد يسبب بعض التعطيل ولكن يمكن إدارته دون صعوبة كبيرة. قد يتضمن تكاليف مالية معتدلة أو انخفاضاً مؤقتاً في الإنتاجية.
4	كبير (Major)	الأثر يسبب تعطيلاً كبيراً للخدمات أو العمليات. قد يؤدي إلى خسارة مالية كبيرة، أو ضرر جسيم للسمعة، أو تخصيص موارد كبيرة للمعالجة.
5	كارثي (Catastrophic)	الأثر شديد لدرجة أنه يهدد وجود البنك واستمرار عملياته. قد يؤدي إلى ضرر طويل الأمد أو دائم للسمعة أو الاستقرار المالي. قد يتضمن تبعات قانونية وخسائر مالية كبيرة.

ترتيب أولويات المخاطر (Risk Prioritisation)

يقوم بنك الأفاق الرقمية بعد ذلك بترتيب المخاطر بناءً على احتمالياتها وأثرها للمساعدة في التركيز على الأكثر أهمية. استخدام مزيج من (الأثر × الاحتمالية) يعطي كل خطر تصنيفاً إجمالياً.

الأولويات العليا هي مخاطر الربع ذات الاحتمالية العالية والأثر العالي.

→	1 بعيد	2 غير محتمل	3 ممكن	4 محتمل	5 محتمل جداً
5 كارثي	5	10	15	20	25
4 كبير	4	8	12	16	20
3 معتدل	3	6	9	12	15
2 بسيط	2	4	6	8	10
1 ضئيل	1	2	3	4	5

مستويات التصنيف:

- **أحمر (Extreme):** مخاطر قصوى تهدد استمرار عمليات البنك (25-16)
- **برتقالي (High):** مخاطر عالية تهدد عمليات الخدمة (15-11)
- **أصفر (Medium):** مخاطر متوسطة تسبب إزعاجاً لكن يمكن التعامل معها (10-5)
- **أخضر (Low):** مخاطر منخفضة يجب حلها لكن لن تسبب مشاكل تشغيلية ملحوظة (4-1)

Risk Mitigation (تخفيف المخاطر)

- سيقوم فريق أمن المعلومات بعد ذلك بتطوير استراتيجيات لإدارة المخاطر ذات الأولوية. هناك أربعة أساليب رئيسية لتخفيف المخاطر:

الخيار	الوصف	متى نستخدمه
القبول (Accept)	إذا كان للخطر احتمالية وأثر منخفضان، قد يكون من المقبول الاعتراف به ومراقبته.	مخاطر منخفضة
التجنب (Avoid)	إذا أمكن، غير خططك لتجنب الخطر تماماً.	عندما يكون الخطر كبير ولا يمكن تخفيفه
النقل (Transfer)	انقل الخطر إلى طرف آخر (مثل التأمين أو الاستعانة بمصادر خارجية).	مخاطر يمكن تأمينها
التخفيف (Mitigate)	نفذ إجراءات لتقليل احتمالية و/أو أثر الخطر (مثل التدريب الإضافي، خطط النسخ الاحتياطي، تنويع الموردين).	الخيار الأكثر شيوعاً

يجب أن يوثق سجل المخاطر بوضوح خيارات معالجة المخاطر المختارة (قبول، تجنب، نقل، تخفيف). يجب تبرير كل قرار بناءً على تقييم المخاطر وشهية المخاطر في البنك.